DAST con OWASP ZAP

Metodología — Ronda 3

Equipo SOS Clinic

22 de octubre de 2026

1 Objetivo

Analizar dinámicamente el frontend estático en busca de problemas de configuración, cabeceras, exposición de información y patrones pasivos de riesgo, sin lanzar ataques activos ni afectar datos.

2 Alcance

- Objetivo: `http://host.docker.internal:5500`, que corresponde al servidor del frontend en el puerto 5500 de la máquina anfitriona.
- 17 URLs descubiertas por el *spider* de ZAP.
- Perfil **baseline** (pasivo): no se ejecutan ataques de inyección ni escaneos activos.
- Sin autenticación: se analiza la superficie pública (landing, login, recuperación de clave y páginas estáticas).

3 Herramienta

Elemento	Detalle
Imagen	`ghcr.io/zaproxy/zaproxy:stable`
Script	`zap-baseline.py`
Perfil	Baseline pasivo
Objetivo	`http://host.docker.internal:5500`
Fecha	22 de octubre de 2026

Cuadro 1: Configuración de la ejecución de ZAP.

4 Procedimiento

1. Verificar que un contenedor alcanza el frontend local mediante `host.docker.internal`.
2. Ejecutar ZAP con el perfil baseline, limitando el *spider* a un minuto y esperando el análisis pasivo.
3. Generar reportes HTML, JSON y Markdown en `seguridad/resultados/`.
4. Clasificar cada advertencia por impacto real y contexto de la aplicación.

```
docker run --rm \
  -v <repo>/seguridad/resultados:/zap/wrk:rw \
```

```
ghcr.io/zaproxy/zaproxy:stable zap-baseline.py \
-t http://host.docker.internal:5500 \
-r zap-baseline-r3.html \
-J zap-baseline-r3.json \
-w zap-baseline-r3.md
```

5 Criterios

ZAP clasifica cada regla como `PASS`, `WARN` o `FAIL`. Un `FAIL` indica una vulnerabilidad o configuración claramente insegura; un `WARN` requiere evaluación manual. En esta ronda se revisó cada advertencia y se documentó si era un riesgo real, una decisión intencional o un residual conocido.

6 Limitaciones

- El escaneo es pasivo: no prueba inyección, lógica de negocio ni autenticación.
- No se autenticó una sesión, por lo que las páginas internas no se analizaron con datos reales.
- El frontend es estático y carga datos por JavaScript; ZAP no ejecuta todos los flujos de la SPA.
- El entorno usa HTTP local; las reglas de HSTS no aplican.
- No sustituye el pentest manual ni una revisión de código.

7 Reproducción

El comando anterior deja los tres reportes. Para revisar el resultado sin navegador, el JSON se puede resumir con las reglas y sus ocurrencias.